



File No.: EXP202209077

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for the Protection of Data and based on the following

BACKGROUND

FIRST: On July 15, 2022, Mr. A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for the Protection of Data. The complaint is directed against ALL ABOUT WATER, S.L. with NIF B42542290 (hereinafter AAW or the respondent). The reasons on which the complaint is based are as follows:

The complainant submitted a complaint to the responsible party of the website thebath.es, related to a product purchased through it. His complaint, identified with the number ***COMPLAINT.1, was closed and linked to another identified with the number ***COMPLAINT.2, associated with another order made by a third party. This, according to the documentation provided by the complainant, resulted in the third party having access to the complainant's personal data related to the order made (name, surname, full address, and phone number).

Along with the notification, the following is provided:

- A copy of the communications maintained with the respondent on July 15, 2022, regarding a complaint related to the purchased products. It includes a communication sent on the same day from the email address of the respondent (support@thebath.zendesk.com) and addressed to a third party, with a copy to the complainant, which contains a thread in which they inform him, among other things, that request number ***COMPLAINT.1 was closed and merged with request number ***COMPLAINT.2. This thread contains information about the order made by the complainant and includes identifying data of this (name and surname) and contact data (phone number and postal address).

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the respondent, so that it could proceed to its analysis and inform this Agency within one month of the actions carried out to comply with the requirements set forth in the data protection regulations. The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), by electronic notification, was received on September 6, 2022, as stated in the certificate in the file. No response has been received to this forwarding letter.

THIRD: On October 15, 2022, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigation actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the following aspects:

Date on which the claimed facts occurred: July 15, 2022.

The respondent has been requested by the Data Inspection to provide information and documentation regarding the reported facts. On December 7, 2022, a written response to the information request was received by this Agency, in which it states the following:

- o The entity has a system to respond to customers via tickets; these tickets are managed manually, and when a customer sends several different emails or several messages through different channels, the person in charge of managing them "merges" some tickets and others from the same customer to maintain a single thread of conversation. In this specific case, that manual merging was done by mistake with another customer's ticket, as the merging is done with codes; in this case, a change of number caused the error.

o It is not aware of having received complaints from other customers regarding these facts.

o It provides a copy of the history of the conversation with the customer (here complainant), in which it is verified that he communicates the following: "Good afternoon, I do not understand why you have merged my request ***COMPLAINT.1 from order (...) with this other one that has nothing to do with me. You have considered the other one resolved and I cannot add any comments... My personal data that appears here has been made available to a third party that has nothing to do with the case and seriously violates data protection law. I request that you take action immediately." It is verified that 11 minutes later the entity responds as follows: "We have proceeded to resolve it. We are sorry. Best regards."

The respondent indicates that on the same day, July 15, it proceeded to remove the CC (Carbon Copy) from the communications so that no further tickets would be received by both users.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/17

o

It does not provide, as requested, information and documentation evidencing the controls and security measures associated with the confidentiality of the information directed to employees.

o

It does not provide, as requested, a report on the technical and organizational measures adopted to prevent similar incidents from occurring, implementation dates, and controls carried out to verify their effectiveness.

o

Regarding the actions taken to minimize the adverse effects of this incident and those adopted for its final resolution, it states that the managers responsible for handling those tickets have been notified about the error made, so that in future occasions they exercise much more caution with any merging, although no documentation is provided to substantiate this. It claims that this has never happened before, nor after these events, and that it is a completely isolated incident due to human error.

The entity being claimed was again requested by the Data Inspection on March 24, 2023, to provide information and documentation evidencing the controls and security measures associated with the confidentiality of the information directed to employees and to report on the technical and organizational measures adopted to prevent similar incidents from occurring, implementation dates, and controls carried out to verify their effectiveness, without any response received.

FIFTH: According to the report obtained from the AXESOR tool, the entity ALL ABOUT WATER, S.L. is a company established in 2017, with a turnover of (...), in the fiscal year 2021.

SIXTH: On October 6, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the claimed party, in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), for the alleged infringement of Article 5.1.f) of the GDPR, classified in Article 83.5 of the GDPR, and for the alleged infringement of Article 32 of the GDPR, classified in Article 83.4 of the GDPR.

The initiation agreement was sent, in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), by electronic notification, being received on October 6, 2023, as stated in the certificate in the file.

SEVENTH: Once the aforementioned initiation agreement was notified in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), the claimed party submitted a written statement in which, in summary, it stated that this fact indeed occurred, taking no more than ELEVEN minutes to take measures to safeguard its client's data. It asserts that it has a security document regarding data protection that guarantees the rights, as well as the protection of the data it processes, in order to provide its services to its clients and ensure the proper use of personal data.

To substantiate its claims, it states that it proceeds to attach the following documentation:

- DOC.1 Data Protection Policy
- DOC.2 Record of Processing Activities
- DOC.3 Informative Clause
- DOC.4 Basic Informative Clause
- DOC.5 Detailed Informative Clause
- DOC.6 Employee Use Rules
- DOC.7 Personal Decalogue
- DOC.8 Clean Desk Policy
- DOC.9 Printer Policy
- DOC.10 Shredder Policy
- DOC.11 Internal Policy on Digital Disconnection in the Workplace
- DOC.12 Management of Security Breaches
- DOC.13 Policy for Reporting Security Breaches
- DOC.14 Best Practices in Password Management

It states that from this documentation, the measures taken by the company can be observed with the intention of remedying the error made, both internally and with its personnel, thus ensuring compliance with the GDPR.

Finally, it indicates that the security breach that occurred was reported to the Agency and measures were taken to prevent the incident from recurring, a circumstance that it claims can be verified from the documentation provided.

For all the above reasons, it requests the filing of the initiation of the sanctioning file for complying with the requirements established in the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/17

EIGHTH: On July 11, 2024, the Director of the Spanish Agency for Data Protection, in relation to sanctioning procedure No. EXP202209077 initiated by this Agency against ALL ABOUT WATER, S.L., in accordance with the powers conferred by Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), agreed to appoint B.B.B. as the Instructor of the procedure, in place of C.C.C., indicating that they could be recused, if applicable, at any time during the processing of the procedure, in accordance with the provisions of Article 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

This agreement was sent, in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), by electronic notification, being received on July 12, 2024, as stated in the certificate in the file.

NINTH: On July 17, 2024, as part of the documentation that was stated to be provided was not received, a request was made for it to be submitted within a period of 5 days, indicating that, if not done, the processing of the procedure would continue, in accordance with the provisions of Article 77 of the LPACAP.

The aforementioned request was notified in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), and after the granted period had elapsed, it has been confirmed that no allegations have been received from the requested party.

TENTH: On August 27, 2024, a proposal for resolution was formulated, proposing:

<< “That the Director of the Spanish Agency for Data Protection sanctions ALL ABOUT WATER, S.L., with NIF B42542290,

- for the infringement of Article 5.1.f) of the GDPR, classified in accordance with the provisions of Article 83.5 of the GDPR, qualified as very serious for the purposes of prescription, in Article 72.1 a) of the LOPDGDD, with a fine of 5,000 euros.

- for the infringement of Article 32 of the GDPR, classified in accordance with the provisions of Article

83.4 of the GDPR, qualified as serious for the purposes of prescription, in Article 73 f) of the LOPDGDD, with a fine of 3,000 euros.

That the Director of the Spanish Agency for Data Protection orders ALL ABOUT WATER, S.L., with NIF B42542290, to implement, under Article 58.2.d) of the GDPR, the necessary corrective measures within one month to adapt its actions to the personal data protection regulations, preventing similar events from occurring in the future, and to inform this Agency, within the same period, about the measures adopted.” >>

The aforementioned proposal for resolution was sent, in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), by electronic notification, being received on August 29, 2024, as stated in the certificate in the file.

ELEVENTH: On September 12, 2024, the requested entity submitted a written statement of allegations to the Proposal for Resolution, in which, in summary, it attached the following documentation:

- Reduced informative clause for interested parties.
- Informative document on secure and confidential destruction of information.
- Record of Processing Activities.
- Security of processing.
- Information in compliance with personal data protection regulations.
- Data Protection Policy document.
- Document on the policy for notifying and communicating personal data security breaches.

In view of all that has been acted upon, the Spanish Agency for Data Protection considers the following facts to be proven in the present procedure,

PROVEN FACTS

FIRST: There is a communication sent from the email address of the requested entity (support@thebath.zendesk.com) directed to a third party with a copy to the claimant, which contains a thread informing them, among other things, that request number ***RECLAMACIÓN.1 was closed and merged into request number ***RECLAMACIÓN.2. This thread contains information about the order made by the claimant and includes identifying data of the claimant (name and surname) and contact information (phone number and postal address).

SECOND: On July 15, 2022, it is recorded that the claimant communicated the following: “Good afternoon, I do not understand why you have merged my request ***RECLAMACIÓN.1 for the order (...) with this other one that has nothing to do with me. You have considered the other one resolved and I cannot add any comments... My personal data that appears here has been made available to a third party that has nothing to do with the case and severely violates data protection law. I request that you take immediate action.”

THIRD: It is verified that 11 minutes later the entity responded as follows:

7/17

“we have proceeded to resolve it. We apologize. Best regards.”

FOURTH: The respondent indicates that on the same day, July 15, it proceeded to remove the CC (With Copy) from the communications so that no ticket would be received by both users.

FIFTH: The respondent submits a written statement of allegations in which it acknowledges that the incident occurred and that it took no more than eleven minutes to take measures to safeguard its client's data.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

In the present case, in accordance with Article 4.1 of the GDPR, there is evidence of the processing of personal data, since the respondent carries out, among other processing activities, the collection, registration, storage, use, access, and deletion of personal data of individuals, such as: name and surname, N.I.F, postal address, telephone number, email address, etc.

The respondent carries out this activity in its capacity as data controller, as it is the one who determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR.

Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" (hereinafter personal data breach) as "all breaches of security that lead to the accidental or unlawful destruction, loss, alteration of, or unauthorized disclosure or access to personal data transmitted, stored, or otherwise processed."

In this case, there is a personal data breach under the circumstances indicated above, categorized as a confidentiality breach due to the exposure of the claimant's personal data to an unauthorized third party.

Within the principles of processing provided for in Article 5 of the GDPR, the integrity and confidentiality of personal data are guaranteed in paragraph 1.f) of the aforementioned article. For its part, the security of personal data is regulated in Article 32 of the GDPR, which governs the security of processing.

III

Allegations to the Initiation Agreement

In response to the allegations presented by the respondent entity, the following should be noted:

The respondent entity claims that the documentation provided shows the measures taken with the intention of rectifying the error made, both internally and with the staff, thereby ensuring compliance with the GDPR.

It details below the documentation it attaches.

Upon analyzing the documentation, it should be noted that part of the documentation that it claims to provide in its statement of allegations is not received, and the documentation it does provide does not substantiate the controls and security measures associated with the confidentiality of the information directed at employees. There is also no report on the technical and organizational measures adopted to prevent similar incidents, implementation dates, and controls carried out to verify their effectiveness. Finally, there is also no record of the notification of the personal data breach to this Agency.

It is evident that the mere mention of such documentation does not constitute or substantiate the implementation of such measures.

This Agency is surprised that nothing has been provided to date despite the requests made both during the preliminary proceedings and in the allegations phase.

Consequently, the information provided allows us to affirm that there is a deficiency in the compliance with the proactive obligations that the current data protection regulations require of the data controller. The principle of proactive responsibility is the central axis of the GDPR and requires, for its compliance, a conscious, diligent, and continuous attitude on the part of the entities. This attitude is not based solely on reacting when something occurs, but requires always being ahead, which means that, preventively, security measures and controls must be implemented to guarantee the privacy of personal data. And to demonstrate compliance, a matter that has not been substantiated.

From the instruction of the procedure, as inferred from the Established Facts, it has been confirmed that the security measures that the respondent had implemented regarding the data it processed as a controller were not adequate at the time the personal data security breach occurred, specifically concerning the processing procedure of

28001 – Madrid
sedeagpd.gob.es
9/17

customer complaints, as it is carried out through a manual process in which, according to their statements, it is not unusual for customers to send messages through different channels, resulting in the generation of different tickets related to the same complaint. The person in charge then merges them and manages them in a single thread of conversation, with this system being susceptible to errors, as has been demonstrated in the case at hand, which has led to a violation of the confidentiality of personal data.

It is evident that the implementation of security measures could help prevent incidents like the one occurring in this procedure in the future and would improve the quality of the complaint processing procedure. Therefore, the absence of a more secure system in the post-sale complaint management process indicates the insufficiency of reasonable technical and organizational measures based on the estimated potential risks.

In any case, the error that the responding party claims to have committed does not exempt them from liability, since, according to established case law, the existence of such an error cannot be considered when it is attributable to the person suffering it or could have been avoided with greater diligence. In this case, the alleged error is incompatible with the diligence that the entity is obliged to observe, as security measures must be adopted in consideration of each and every risk present in the processing of personal data, including the human factor.

On the other hand, the claim that it took no more than eleven minutes to take measures to safeguard the client's data cannot be accepted, since the email was sent to a third party and the subsequent measures did not eliminate the risks posed to the complainant's data protection, as the data had already been sent, and it was at that moment that the loss of control over the personal data occurred, as the complainant lost the power of disposition over them.

Consequently, the allegations must be dismissed, noting that the arguments presented do not undermine the essential content of the infringement declared nor do they constitute sufficient justification or exculpation.

IV

Allegations to the Resolution Proposal

In response to the allegations presented by the responding entity, the following should be noted:

Upon analyzing the allegations presented, it is verified that neither the documentation provided by the responding entity nor the interpretation of its content reveals any circumstance that could undermine the essential content of the declared infringements, as the controls and security measures associated with the confidentiality of the information directed to employees remain unproven. There is also no report on the technical and organizational measures adopted to prevent similar incidents, implementation dates, and controls carried out to verify their effectiveness.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

10/17

As already indicated in the response given by this Agency to the allegations presented regarding the Initiation Agreement, the documentation provided does not constitute or prove the implementation of such measures.

Therefore, it is appropriate to refer to the response given by this Agency, which is transcribed in the Legal Basis III of this Resolution.

V

Unfulfilled Obligation

Article 5.1.f) "Principles relating to processing" of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by applying appropriate technical or organizational measures ('integrity and confidentiality')."

In this case, it is established that the personal data of the complainant was improperly exposed to a third party, as the complaint of the customer (here the complainant) was merged with that of another customer, which caused that other customer to receive copies of the communications maintained with the complainant, which included their personal data (name and surname, phone number, postal address, and email).

Consequently, it is considered that the established facts constitute an infringement, attributable to the responding party, for violation of Article 5.1.f) of the GDPR.

VI

Classification and Qualification of the Infringement

The aforementioned infringement of Article 5.1.f) of the GDPR constitutes the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to 4% of the total annual global turnover of the preceding financial year, whichever is higher:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/17

For the purposes of the statute of limitations, Article 72 "Very Serious Offenses" of the LOPDGDD states:

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following offenses are considered very serious and shall be subject to a three-year statute of limitations for substantial violations of the articles mentioned therein, particularly the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

VII

Sanction

For the purpose of determining the amount of the sanction for the violation of Article 5.1 f) of the GDPR, it is appropriate to adjust the fine according to the criteria established in Article 83.2 of the GDPR, taking into account:

- Article 83.2.a) GDPR: Nature, severity, and duration of the infringement.

The nature of the infringement is considered serious as it entails a loss of confidentiality and, therefore, an irreparable loss of disposition and control over personal data.

Furthermore, it is deemed appropriate to adjust the sanction to be imposed according to the following criteria established in paragraph 2 of Article 76 "Sanctions and Corrective Measures" of the LOPDGDD:

As aggravating factors:

- Article 76.2.b) LOPDGDD. Linkage of the infringer's activity with the processing of personal data: The entity in question is engaged in online retail sales of products (sanitary ware, plumbing, and bathroom furniture), thus necessitating the continuous processing of personal data of its customers.

Considering the factors presented, the assessed amount of the fine is 5,000 (five thousand euros) for the violation of Article 5.1 f) of the GDPR.

VIII

Obligation Breached

Article 32 "Security of Processing" of the GDPR establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying probabilities and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this Article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law." (the underlining is ours)

It should be noted that the GDPR in the cited provision does not establish a list of security measures applicable according to the data being processed, but rather establishes that the controller and the processor shall implement technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the probabilities and severity of risks to the rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the identified risk, indicating that the determination of technical and organizational measures must be made taking into account: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, and a process of verification (which is not an audit), assessment, and evaluation of the effectiveness of the measures. In any case, in assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial damage.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/17

In this same sense, Recital 83 of the GDPR states that "(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the inherent risks of the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and

the nature of the personal data that needs to be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, which may particularly cause physical, material, or immaterial damage.”

In the present case, AAW is engaged in online sales through the internet of certain products, electronically addressing the claims made by customers, which poses a risk in the processing of personal data that must be evaluated and taken into account.

Therefore, it must exercise special diligence in the technical and organizational measures to ensure adequate security in the processing of personal data, establishing appropriate procedures and measures for this purpose. Among others, establishing a secure system in the post-sale claims management process.

According to the defendant's own statements, it uses a system to respond to customers via tickets, which are managed manually, and when a customer sends several different emails or multiple messages through different channels, the person in charge of managing them “merges” some tickets and others from the same customer to maintain a single thread of conversation.

Therefore, at the time of the breach, it cannot be stated that the defendant had adequate security measures in place based on the potential estimated risks to prevent the incident, specifically regarding the process of handling customer claims, since it is carried out through a manual process and, according to their statements, it is not unusual for customers to send messages through different channels, resulting in the generation of different tickets related to the same claim, with the person in charge merging them and managing them in a single thread of conversation, this system being susceptible to errors, as has been demonstrated in the case at hand, which allowed a third party to access the personal data of the claimant.

The responsibility of the defendant is therefore determined by the security breach evidenced in the claim and by the lack of sufficient accreditation, through the documentation provided, of the controls and security measures aimed at preventing incidents like the one that occurred, since it is responsible for making decisions intended to effectively implement the appropriate technical and organizational measures to ensure an adequate level of security relative to the risk.

Consequently, it is considered that the established facts constitute an infringement, attributable to the defendant, for violation of Article 32 of the GDPR.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

14/17

IX

Classification and Qualification of the Infringement

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” states:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to 2% of the total annual global turnover of the preceding financial year, opting for the higher amount: a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)” In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements.”

For the purposes of the limitation period, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a limitation period of two years:

f) The failure to adopt those technical and organizational measures that are appropriate to ensure an adequate level of security relative to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679. (...)

X

Sanction

For the purpose of determining the amount of the sanction for the infringement of Article 32 of the GDPR, it is appropriate to graduate the fine according to the criteria established in Article 83.2 of the GDPR, taking into account:

- Article 83.2.a) GDPR: Nature, gravity, and duration of the infringement.

It is considered that the nature of the infringement is serious since it implies that the defendant does not have adequate technical and organizational measures to ensure an adequate level of security relative to the risk, or, if such measures exist, they have not been observed or correctly implemented. Furthermore, it is considered appropriate to graduate the sanction to be imposed in accordance with the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/17

the following criteria established in section 2 of article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

- Article 76.2.b) LOPDGDD. Linkage of the infringer's activity with the processing of personal data: The entity in question is engaged in online retail sales via the internet of products (sanitary ware, plumbing, and bathroom furniture), thus necessitating the continuous processing of personal data of its customers.

Considering the factors presented, the assessed amount of the fine is €3,000 (three thousand euros) for the infringement of article 32 of the GDPR.

XI

Adoption of measures

The text of the resolution establishes what the committed infringements are and the facts that have led to the violation of data protection regulations, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully understands their organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

In this case, this authority hereby requires the responsible party to implement the necessary corrective measures within one month to align their actions with personal data protection regulations to prevent similar incidents from occurring in the future, as well as to inform this Agency, within the same timeframe, about the measures adopted.

It is warned that failure to comply with the order to adopt measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning proceedings.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on ALL ABOUT WATER, S.L., with NIF B42542290,

- for the infringement of article 5.1.f) of the GDPR, classified in accordance with the provisions of article 83.5 of the GDPR, qualified as very serious for the purposes of prescription, in article 72.1 a) of the LOPDGDD, a fine of €5,000.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid
sedeagpd.gob.es
16/17

- for the infringement of Article 32 of the GDPR, classified according to the provisions of Article 83.4 of the GDPR, deemed serious for the purposes of prescription, in Article 73 f) of the LOPDGDD, with a fine of 3,000 euros.

SECOND: TO ORDER ALL ABOUT WATER, S.L., with NIF B42542290, to, pursuant to Article 58.2.d) of the GDPR, within 1 month from the date this resolution becomes final and enforceable, demonstrate that it has implemented the necessary corrective measures to align its actions with personal data protection regulations, preventing similar incidents from occurring in the future, as well as to inform this Agency, within the same timeframe, about the measures adopted.

THIRD: NOTIFY this resolution to ALL ABOUT WATER, S.L.

FOURTH: This resolution will be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has elapsed without the interested party having exercised this right. The sanctioned party is warned that they must pay the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account no.

IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed during the executive period.

Upon receipt of the notification and once enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second month following or the next business day thereafter.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative process in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

17/17

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the final resolution in the administrative process may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by writing to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation that

proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es